

Mapeo Normativo Detallado

Trazabilidad de las 50 Métricas GQM-PRAGMATIC a Requisitos Regulatorios

Kit GQM-PRAGMATIC v2025.1 • España / UE • Abril 2026

"El mapa no es el territorio —decía Korzybski— pero sin mapa, el territorio devora al explorador. Esta tabla es el mapa de la conformidad: cada métrica tiene su coordenada regulatoria, y el auditor puede encontrarlas todas sin perderse en la maleza normativa."

Leyenda de Marcos Regulatorios

Código	Marco / Norma	Ámbito de Aplicación en España
NIS2	Directiva UE 2022/2555 (NIS2)	Entidades esenciales e importantes (RP + RD transposición 2025)
DORA	Reglamento UE 2022/2554	Sector financiero supervisado: banca, seguros, fintech, IICI
ENS	RD 311/2022 Esquema Nacional de Seguridad	Sector público y proveedores AAPP en España
COSO-ERM	COSO ERM 2017 (20 Principios)	Universal — referente global de ERM
COSO-CGF	COSO CGF 2026 (Principio 8)	Universal — gobierno corporativo del ciberriesgo
ISO27001	ISO/IEC 27001:2022	Universal — certificación de SGSI
ISO27004	ISO/IEC 27004:2016	Universal — métricas de seguridad de la información
NIST-CSF	NIST CSF 2.0 (2024)	Universal — marco de funciones de ciberseguridad
NIST-8286	NIST IR 8286r1 (2023)	Universal — integración ERM-ciber
FAIR	ANSI/OpenFAIR 2023	Universal — cuantificación financiera del riesgo ciber
AIAct	Reg. UE 2024/1689 (EU AI Act)	Sistemas IA de alto riesgo: desde agosto 2026
GDPR	Reg. UE 2016/679 + LOPDGDD	Universal — protección de datos personales

Matriz de Trazabilidad Normativa Completa

Cód. Métr ica	Deno mina ción Corta	PRA GMA TIC	NIS2	DOR A	ENS	COS O- ERM	COS O- CGF	ISO2 7001	NIST- CSF	FAIR	AIAC T	GDP R
M- GOB- 01	Frec. revisi ón ciber riesg o Cons ejo	39	Art.2 0(1)	Art.5	org.1	P- 2,P-3	P-8	A.5.1	GV.O C-04	—	—	—
M- GOB- 02	% cons ejero s con comp .ciber	32	Art.2 0(2)	Art.5 (4)	op.ac c.1	P-2	P-8	A.6.3	GV.O C-03	—	—	—
M- GOB- 03	Nivel activi dad Comi té Ciber	33	Art.2 0(1)	Art.5	org.2	P- 2,P-3	P-8	A.5.1	GV.O C-04	—	—	—
M- GOB- 04	Inde pend encia repor te CISO	38	Art.2 0(1)	Art.5	org.4	P-2	P-8	A.5.1	GV.O C-05	—	—	—
M- GOB- 05	Apeti to ciber riesg o en euros	39	Art.2 1(1)	Art.6	org.3	P-9	P-8	A.5.2 9	GV.R M-04	CRQ	—	—
M- EST- 01	Integ ració n ciber en estra tegia	34	Art.2 1(1)	Art.6	org.1	P- 6,P-7	P-8	A.5.2 9	GV.R M-04	—	—	—

M-EST-02	Metodología cuantificación riesgo	34	Art.21(1)	Art.8	mp.info.2	P-9,P-10	P-8	A.8.16	GV.RM-07	FAIR/ALE	—	—
M-EST-03	ALE total portafolio (€/año)	36	Art.21(1)	Art.8(3)	mp.info.2	P-9	P-8	A.5.29	GV.RM-07	ALE	—	—
M-EST-04	Frec. actualización cuantificación	35	Art.21(1)	Art.8	op.ex p.1	P-9	—	A.8.1	GV.RM-07	FAIR	—	—
M-EST-05	Ratio cobertura seguro/AL E	37	Art.21	Art.9	—	P-9,P-10	—	A.5.29	GV.RM-06	ROSI	—	—
M-DET-01	MTT D (horas)	39	Art.23(1)	Art.19(1)	op.ex p.7	P-15,P-16	—	A.5.25	DE.AE-06	—	—	Art.33 GDP R
M-DET-02	MTT R (horas)	39	Art.23(1)	Art.19	op.ex p.7	P-15,P-16	—	A.5.26	RS.AN-07	—	—	—
M-DET-03	Tendencia MTT D trimestral	40	Art.23	Art.19	op.ex p.7	P-16	—	A.8.16	DE.AE-06	—	—	—

M- DET- 04	% incid entes detec tados inter name nte	34	Art.2 3(2)	Art.1 9	op.ex p.7	P-15	—	A.5.2 5	DE.A E-07	—	—	—
M- DET- 05	Dwel l Time medi o (días)	37	Art.2 3	Art.1 9	op.ex p.7	P-16	—	A.5.2 5	DE.A E-06	—	—	Art.3 3 GDP R
M- VUL- 01	Time -to- Pate h crític o (días)	40	Art.2 1(2e)	Art.9 (4)	op.ex p.4	P- 13,P- 15	—	A.8.8	ID.R A-01	—	—	—
M- VUL- 02	% CVE crític os sin parc hear >30d	39	Art.2 1(2e)	Art.9 (4)	op.ex p.4	P-13	—	A.8.8	ID.R A-01	—	—	—
M- VUL- 03	% VM prior izada s con EPSS	35	Art.2 1(2e)	Art.9	op.ex p.4	P-13	—	A.8.8	ID.R A-01	—	—	—
M- VUL- 04	Cobe rtura VM en OT/I oT	37	Art.2 1(2c)	—	mp.c om.2	P-13	—	A.8.9	PR.A A-02	—	—	—

M-VUL-05	% apps críticas con SBO M <90d	35	Art.2 1(2d)	Art.9	mp.s w.2	P-12	—	A.8.3 0	ID.SC -04	—	—	—
M-IAM-01	% cuentas priv. con MFA	41	Art.2 1(2j)	Art.9 (2)	op.ac c.5	P-13,P-15	—	A.8.5	PR.A A-03	—	—	—
M-IAM-02	% accesos remotos/cloud con MFA	41	Art.2 1(2j)	Art.9 (2)	op.ac c.5	P-13	—	A.8.5	PR.A A-03	—	—	—
M-IAM-03	Días desde revisión cuentas priv.	37	Art.2 1(2j)	Art.9 (2)	op.ac c.4	P-13	—	A.5.1 6	PR.A A-05	—	—	—
M-IAM-04	Tiempo desprovisión bajas (h)	40	Art.2 1(2j)	Art.9	op.ac c.4	P-13	—	A.5.1 8	PR.A A-05	—	Art.1 7 GDP R	Art.1 7 GDP R
M-IAM-05	% identidades no humanas gobernadas	34	Art.2 1(2j)	Art.9	op.ac c.3	P-13	—	A.5.1 6	PR.A A-02	—	Art.2 5 AIAC T	—

M-SCM-01	% prov. Tier-1 evaluados <12m	37	Art.2 1(2d)	Art.2 8(1)	op.ex t.1	P-12	—	A.5.1 9	ID.SC -02	—	—	Art.2 8 GDP R
M-SCM-02	% prov. monitorización continua	39	Art.2 1(2d)	Art.2 8	op.ex t.1	P-12	—	A.5.1 9	ID.SC -02	—	—	—
M-SCM-03	% contratos con cláusulas seguridad	35	Art.2 1(2d)	Art.3 0	op.ex t.2	P-12	—	A.5.1 9	ID.SC -03	—	Art.2 8 AIAC T	Art.2 8 GDP R
M-SCM-04	% servicios con BC ante fallo prov.	37	Art.2 1(2c)	Art.2 8(6)	op.ex t.3	P-14	—	A.5.3 0	RC.R P-02	—	—	—
M-SCM-05	% apps terceros con SBO M monitorizados	31	Art.2 1(2d)	Art.9	mp.s w.2	P-12	—	A.8.3 0	ID.SC -04	—	Art.2 8 AIAC T	—
M-RES-01	Ratio RTO real/objetivo (%)	41	Art.2 1(1)	Art.11 (1)	mp.c om.9	P-14,P-16	—	A.5.3 0	RC.R P-03	—	—	—

M-RES-02	Ratio RPO real/objetivo (%)	41	Art.21(1)	Art.11	mp.com.9	P-14,P-16	—	A.8.13	RC.RP-03	—	—	—
M-RES-03	Nº pruebas DRP reales en 12m	37	Art.21(1)	Art.11(4)	op.ex.p.9	P-14	—	A.5.30	RC.RP-05	—	—	—
M-RES-04	% ejercicios table top con C-level	36	Art.20	Art.5, Art.11	org.2	P-14	P-8	A.5.30	RC.RP-05	—	—	—
M-RES-05	% backups inmutables verificados	40	Art.21(2c)	Art.11	mp.com.9	P-15	—	A.8.13	PR.DS-11	—	—	—
M-EMG-01	% sistemas con inventario criptográfico	38	Art.21(2h)	Art.9(2)	mp.com.3	P-13	—	A.8.24	PR.DS-02	—	—	—
M-EMG-02	Estado hoja de ruta PQC (0-3)	39	Art.21(2h)	Art.9	mp.com.3	P-6,P-7	—	A.8.24	PR.DS-02	—	—	—

M-EMG-03	% reglas SOC para adversarial	35	Art.21(2e)	Art.19	op.ex p.7	P-15	—	A.8.16	DE.CM-09	—	Art.9 AIAC T	—
M-EMG-04	% sistemas IA con eval. riesgo	38	Art.21	Art.9	op.pl.1	P-7,P-8	—	A.5.8	ID.RA-05	—	Art.9-16 AIAC T	—
M-EMG-05	% datos vida >10a eval. SNDL	35	Art.21(2h)	Art.9	mp.i nfo.3	P-9	—	A.8.24	PR.DS-02	—	—	Art.5 GDP R
M-RPT-01	Frec. reporte ciber al Consejo	39	Art.20(1)	Art.5	org.4	P-18,P-19	P-8	A.5.1	GV.O C-04	—	—	—
M-RPT-02	% indicadores en términos financieros	39	Art.20	Art.5 (4)	org.4	P-19	P-8	A.5.29	GV.O C-04	FAIR	—	—
M-RPT-03	Calidad comparativa estado/apetito	37	Art.21(1)	Art.6	org.3	P-18,P-19	P-8	A.5.29	GV.RM-04	—	—	—

M-RPT-04	Estado protocolo escalado (0-3)	40	Art.23	Art.17,19	op.ex p.7	P-16,P-18	—	A.5.26	RS.C O-03	—	—	Art.33 GDP R
M-RPT-05	Tiempo evento → Consejo (horas)	41	Art.20,23	Art.19	org.4	P-18	P-8	A.5.26	RS.C O-03	—	—	—
M-ROI-01	ROSI del programa (%)	37	Art.21(1)	Art.8	mp.info.2	P-9,P-10	P-8	A.5.29	GV.R M-06	ROSI	—	—
M-ROI-02	Gasto ciber / ingresos (%)	40	Art.21	Art.8	—	P-9	P-8	A.5.29	GV.R M-06	—	—	—
M-ROI-03	Delta ALE por programa (€/año)	37	Art.21(1)	Art.8	—	P-9,P-10	P-8	A.5.29	GV.R M-07	ALE	—	—
M-ROI-04	Payback periodo controles (meses)	39	Art.21	Art.8	—	P-9	P-8	A.5.29	GV.R M-06	FAIR	—	—
M-ROI-05	Ratio inversión/ ALE (%)	39	Art.21(1)	Art.8	—	P-9,P-10	P-8	A.5.29	GV.R M-07	FAIR	—	—

Análisis de Densidad Regulatoria por Métrica

La densidad regulatoria indica cuántos marcos distintos cubre cada métrica.

Densidad	Número de Métricas	Interpretación
7-10 marcos	12 métricas	Métricas con máxima cobertura regulatoria transversal
5-6 marcos	21 métricas	Métricas con alta cobertura regulatoria
3-4 marcos	14 métricas	Métricas con cobertura regulatoria selectiva
1-2 marcos	3 métricas	Métricas con cobertura regulatoria específica

Métricas con Mayor Densidad Regulatoria (Top 10)

Cód. Métrica	Denominación	Marcos cubiertos	PRAGMATIC
M-IAM-01	% cuentas privilegiadas con MFA	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	41 
M-IAM-02	% accesos remotos/cloud con MFA	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	41 
M-RES-01	Ratio RTO real/objetivo	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	41 
M-RES-02	Ratio RPO real/objetivo	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	41 
M-RPT-05	Tiempo evento – Consejo (h)	NIS2:DORA·ENSCOSO-ERM·COSO-CGF·ISO27001·NIST-CSF	41 
M-DET-01	MTTD (horas)	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF·GDPR	39 
M-DET-02	MTTR (horas)	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	39 
M-VUL-01	Time-to-Patch crítico	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF	40 
M-EMG-04	% sistemas IA con eval. riesgo	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF·AIAC	38 
M-SCM-01	% prov. Tier-1 eval. <12m	NIS2:DORA·ENSCOSO-ERM·ISO27001·NIST-CSF·GDPR	37 

Cobertura de Métricas por Marco Regulatorio

Marco	# Métricas con cobertura	Componente COSO más cubierto
NIS2 (Dir. 2022/2555)	50/50 (100%)	C-III Desempeño (mayor volumen)
COSO-ERM 2017	50/50 (100%)	Todos los componentes
ISO/IEC 27001:2022	48/50 (96%)	C-III Desempeño
NIST CSF 2.0	48/50 (96%)	C-III Desempeño (DE, RS, RC)
ENS (RD 311/2022)	44/50 (88%)	C-III Desempeño
DORA (Reg. 2022/2554)	38/50 (76%)	C-III Desempeño + C-V Reporte
COSO-CGF 2026	15/50 (30%)	C-I Gobernanza + C-V Reporte
FAIR (OpenFAIR 2023)	14/50 (28%)	C-II Estrategia
GDPR (Reg. 2016/679)	8/50 (16%)	C-III Desempeño (IAM, DET)
EU AI Act (Reg. 2024/1689)	6/50 (12%)	C-II Emergentes

Mapeo Normativo — Kit GQM-PRAGMATIC v2025.1 | Abril 2026

Nota: Las referencias a artículos y controles son indicativas de la cobertura principal. En la implementación, verificar la versión vigente de cada norma y su aplicabilidad específica al perfil de la organización.